Tài liệu dự án SellTime

Tổng quan sản phẩm, kiến trúc và hiện trạng triển khai

Ngày lập: 11/10/2026 · Ngôn ngữ: Tiếng Việt · Đối tượng: chủ dự án, lập trình viên và người review

1 Tổng quan và phạm vi

SellTime là ứng dụng kết nối người có thời gian rảnh với cơ sở cần nhân sự theo ca. Người tìm việc chọn khung giờ, loại việc, khoảng cách và mức lương mong muốn; ứng dụng xếp hạng các ca theo độ phù hợp. Nhà tuyển dụng có giao diện đăng ca, xem ứng viên và theo dõi ca mẫu.

Kết luận hiện trạng: workspace có giao diện DEMO và code Auth/ownership mới. Luồng làm việc, duyệt ứng viên, điểm danh và ví tại trang chính vẫn mô phỏng. SQL/RLS chưa được thực thi trên database test đã được phê duyệt; chưa có cơ sở nghiệm thu Auth LIVE hoặc vận hành giao dịch thật.

Nội dung	Hiện trạng quan sát được
Workspace	C:/Users/admin/OneDrive/Desktop/selltime_project
Git branch	master
Git HEAD	96f4be8575718d50eab2285ab5241d1583f3423a
Cơ sở tài liệu	Code và tài liệu đang tồn tại trong working tree ngày 11/10/2026
Trang chính /	Candidate DEMO và Employer DEMO; dữ liệu mẫu, state cục bộ
Trang /auth	Code Supabase Email/Password riêng; mặc định tắt khi chưa bật cấu hình
RLS integration	NOT_RUN theo báo cáo hiện có; kiểm tra tĩnh không thay thế database test
Admin	Có role ADMIN và API cấp/thu hồi Employer; chưa có trang quản trị

Working tree chứa nhiều thay đổi chưa commit, gồm code Auth và bộ chuẩn bị kiểm thử RLS. Vì vậy, checkout riêng HEAD trên không tái tạo đầy đủ trạng thái được mô tả. Tài liệu này không dựa trên giả định rằng các iteration trước đã được nghiệm thu.

Nhóm người dùng dự kiến là người tìm ca linh hoạt, gồm sinh viên, và cơ sở F&B, bán lẻ hoặc công việc thời vụ. Persona và địa điểm mẫu hiện gắn với khu vực Thái Nguyên. Đây là định hướng sản phẩm trong code, chưa phải bằng chứng nhu cầu, số lượng khách hàng hay doanh thu.

Tài liệu mô tả hiện trạng và đề xuất thứ tự hoàn thiện. Lần tạo tài liệu này không sửa ứng dụng, không chạy SQL, không bật Auth LIVE, không triển khai payment hoặc Admin.

2 Kiến trúc và quy tắc nghiệp vụ

Ứng dụng dùng Next.js App Router và React. Giao diện trang chính phối hợp các component, store DEMO và hàm domain. API Auth dùng Supabase client theo từng request; API shifts/messages kiểm tra danh tính trước khi truy cập dữ liệu. RLS chỉ có thể bảo vệ database thật sau khi migration được áp dụng và kiểm chứng.

Lớp	Trách nhiệm và điểm vào
Giao diện	src/app/page.tsx, src/components: trang DEMO, modal, dashboard và chat
State ứng dụng	src/application/store.ts: persona, ca mẫu và phối hợp state
Domain	src/domain/types.ts, matching-engine.ts, trust-battery.ts
API và Auth	src/app/api, src/infrastructure/auth: xác minh session, role, ownership và Origin
Database và AI	src/infrastructure/database, src/infrastructure/ai/gemini.ts
SQL và kiểm thử	src/database, src/__tests__, scripts

Các version range trong package.json: Next ^15.1.7, React ^19.0.0, TypeScript ^5.7.3, Tailwind ^3.4.17, Supabase JS ^2.117.1 và Google Generative AI SDK ^0.24.1. Đây là khai báo dependency; phiên bản cài cụ thể do lockfile quyết định. Package mssql còn tồn tại cho phần legacy; đường Auth mới không fallback sang SQL Server hoặc memory.

Matching theo ca

Điểm tổng hợp = 35% thời gian + 25% vị trí + 25% kỹ năng + 15% lương, làm tròn trên thang 0–100. Vị trí dùng khoảng cách Haversine; kỹ năng so khớp chuỗi không phân biệt hoa thường. Nhãn: từ 85 rất phù hợp, từ 70 phù hợp cao, từ 50 khá phù hợp, thấp hơn là cân nhắc.

Từ khóa và loại việc lọc danh sách. Khung giờ, khoảng cách và lương tác động điểm xếp hạng; không nên hiểu mọi tiêu chí đó là điều kiện loại trừ cứng. Code chưa chứng minh cơ chế ngăn trùng lịch làm việc thật. Matching là thuật toán có trọng số, không phải mô hình AI học từ hành vi người dùng.

Trust Battery

Ân hạn hủy trong 60 phút từ lúc đặt: không phạt. Ngoài ân hạn: hủy trước ít nhất 12 giờ không phạt; từ 2 đến dưới 12 giờ trừ 15 điểm; dưới 2 giờ trừ 35 điểm và khóa SOS 24 giờ; no-show trừ 50 điểm và khóa SOS 48 giờ. Nhận SOS cần ít nhất 80 điểm và không còn khóa thời gian. Hoàn tất ca thưởng 2 điểm, thêm 2 nếu SOS và thêm 1 nếu được 5 sao. Các hàm domain được kiểm thử; áp dụng hiện tại trong DEMO không tạo quyết định server thật.

3 Luồng trải nghiệm và ranh giới DEMO

Candidate DEMO và Employer DEMO là persona mẫu tại trang chính. Chuyển vai trò giúp xem hai trải nghiệm, không xác thực tài khoản và không cấp quyền server. AuthModal của luồng DEMO không tạo session Supabase thật; trang /auth được tách riêng.

Candidate

Bước	Cách thực hiện hiện tại	Giới hạn
Tìm ca	Dữ liệu mẫu, hàm matching và bộ lọc trong trình duyệt	Chưa là tìm ca công khai qua API Auth
Ứng tuyển	State React và một phần localStorage	Chưa ghi application thật vào database
Được duyệt	Chưa có transition nối với Candidate	Không đồng bộ với nút duyệt DEMO của Employer
Check-in	Modal mô phỏng GPS/QR/PIN; lưu trạng thái và timestamp cục bộ	Chưa có xác minh địa điểm hoặc sự kiện điểm danh server
Đang làm	Timer tính từ timestamp check-in	Không có giám sát ca server
Checkout và hoàn tất	Callback cục bộ đổi trạng thái, cộng thưởng/thu nhập mẫu	Chưa có đối soát và xác nhận của hai bên
Ví	Số dư và thu nhập DEMO	Không chuyển tiền, rút tiền hoặc escrow thật

Employer

Bước	Cách thực hiện hiện tại
Mở trải nghiệm	Chọn Employer DEMO qua role switch
Đăng ca	Form và state cục bộ; không nối thao tác này vào API Auth mới
Xem ứng viên	Danh sách/hồ sơ mẫu
Duyệt hoặc từ chối	State cục bộ trên dashboard
Theo dõi ca	Giao diện và dữ liệu mô phỏng; chưa có đồng bộ lifecycle thật

Một phần dữ liệu DEMO lưu trong localStorage với nhóm khóa selltime_demo_*. Chat mặc định demoOnly và lưu cache theo persona/hội thoại; tin nhắn mẫu không gọi API messages. Tuy nhiên, số dư ví, điểm uy tín và một số mốc thời gian không được persist đầy đủ. Tải lại trang có thể không tái tạo nhất quán toàn bộ phiên DEMO; cần kiểm thử consumer trước khi nghiệm thu luồng này.

Payment/QR, ví, check-in và checkout phải được hiểu là DEMO. Giao diện không phải bằng chứng thanh toán hoặc xác nhận chấm công thật. AI Coach có đường Gemini và fallback cục bộ; metadata nguồn là gemini hoặc local_mock. Việc có code gọi Gemini chưa chứng minh provider hoạt động trong môi trường hiện tại.

Các endpoint /api/ai/cv, /api/ai/gap và /api/ai/interview chưa có lớp Auth/rate limit/quota tương đương API Auth mới. Không nên mở AI công khai trước khi bổ sung bảo vệ và đo chi phí. Lỗi metadata fallback của AiCoach đã được ghi trong deferred-work, chưa được xử lý trong lần tạo tài liệu này.

4 Auth và API đã có trong code

Code Auth mặc định fail-closed: thiếu cấu hình hoặc lỗi provider/database không chuyển sang persona DEMO hay dữ liệu memory để cấp quyền. Mỗi request xác minh token bằng auth.getUser, rồi đọc lại hồ sơ users theo auth_user_id. Role lấy từ database; không tin role trong trình duyệt hoặc JWT metadata.

Token được nhận qua cookie hoặc Bearer header. Cookie access/refresh là HttpOnly, SameSite Strict và Secure trong production. Mutation yêu cầu Origin trùng cấu hình, kể cả khi dùng Bearer token. Response Auth không cache và không trả token trong identity JSON. Các cơ chế này đã có trong code và tests mock; kiểm thử provider/cookie HTTPS thật còn chờ môi trường được duyệt.

Endpoint	Hành vi hiện tại
GET /api/auth/session	Đọc danh tính đã xác minh; role được đọc mới
POST /api/auth/signup	Đăng ký Email/Password; trigger tạo Candidate, không tự nhận Employer/Admin
POST /api/auth/login	Đăng nhập và thiết lập cookie
POST /api/auth/refresh	Kiểm tra Origin, refresh và xác minh lại hồ sơ
POST /api/auth/logout	Kiểm tra Origin, dọn hai cookie; thử kết thúc session local ở provider
POST /api/auth/employer	Chỉ Admin đã xác minh; RPC cấp/thu hồi role Employer
GET /api/shifts	Yêu cầu Auth; đọc ca theo RLS, tối đa 100 ca gần nhất
POST /api/shifts	Chỉ Employer; INSERT ca với owner từ session, ID trùng trả 409
GET/POST/DELETE /api/messages	Kiểm tra thành viên hội thoại; server gán sender; chỉ xóa tin của chính mình

API messages đọc tối đa 150 tin mới nhất và giới hạn nội dung gửi 2.000 ký tự. DELETE cần conversation_id và message_id; không có thao tác reset chat toàn cục. API shifts hiện đọc ca của Employer hoặc ca Candidate đã ứng tuyển theo policy, chưa cung cấp luồng tìm ca công khai hoàn chỉnh.

Chưa có profile API độc lập, API tạo hội thoại hoặc lifecycle ứng tuyển/duyệt/check-in/checkout đầy đủ. Fixture hội thoại và ứng tuyển trong môi trường test cần được provision bằng cơ chế quản trị tin cậy. Trang DEMO chưa trở thành giao diện LIVE chỉ vì các endpoint này xuất hiện.

Quyền và hạn chế

Role ADMIN có trong types/schema và logic guard. Chưa có route /admin hoặc Admin Dashboard. Admin đầu tiên phải được provision tin cậy ngoài ứng dụng trên binding Auth UUID đã xác minh. RPC set_employer_role chỉ đổi Candidate/Employer, không cấp Admin và không cấp quyền tài chính.

Logout dọn cookie cục bộ ngay cả khi session hết hạn hoặc provider lỗi sau Origin guard. Access JWT đã phát hành có thể còn hiệu lực đến expiry. Refresh fail-closed có thể buộc người dùng đăng nhập lại khi provider hoặc truy vấn hồ sơ tạm thời lỗi; tradeoff này còn cần review.

5 Database và chuẩn bị RLS

Schema nền Supabase mô tả users, candidate_profiles, employer_profiles, shifts, shift_applications và escrow_transactions. Migration 006 bổ sung binding Auth UUID và hai bảng conversations/messages, tạo thành 8 bảng ứng dụng; bộ chuẩn bị offline kiểm tra 7 enum. Đây là cấu trúc file SQL, chưa phải inventory được xác nhận từ database đang chạy.

Nhóm dữ liệu	Quan hệ và mục tiêu bảo vệ của migration
users và profile	Liên kết auth_user_id với hồ sơ; quyền đọc/sửa hồ sơ được giới hạn
shifts	Employer sở hữu ca; INSERT kiểm tra owner, role và tên/avatar khớp hồ sơ
shift_applications	Candidate và Employer sở hữu ca chỉ đọc dữ liệu liên quan
conversations/messages	Thành viên hội thoại mới đọc/gửi; sender chỉ xóa tin của mình
escrow_transactions	Khóa quyền đọc/ghi client trong phạm vi migration hiện tại
Cột nhạy cảm	Không cho client tự đổi role, Auth UUID, KYC, trust, escrow hoặc PIN

Migration dùng RLS, grants theo cột, trigger signup và RPC đổi Employer. Các hàm có đặc quyền cần review security definer/search_path. Tên/avatar khi đăng ca là snapshot hồ sơ; không phải chứng nhận pháp lý. Seed DEMO không được tự gắn vào Auth theo email. Email trùng giữa DEMO unbound và signup thật là vấn đề đã ghi nhận.

Các tệp cần đọc trước database test

- 006_auth_ownership.sql: migration Auth/ownership.
- 000_test_baseline.sql: bootstrap DDL cho Supabase test trống, không seed.
- 006_auth_ownership.sql — tests: suite fixture trong transaction và rollback, mô phỏng claims/role SQL.
- 006_verify_rollback.sql: kiểm tra collision trước test và residue sau rollback, cần quyền đọc phù hợp.
- rls-integration-test-plan.md: dependency, quyền, thứ tự thực thi và checkpoint approval.

Điều kiện thực thi: xác định đúng Supabase project test riêng, quyền người thực thi, công cụ kết nối và phê duyệt bootstrap/migration/fixture/suite/hậu kiểm. Không dùng database production cho fixture. Rollback fixture không hoàn tác các COMMIT của bootstrap hoặc migration. Không tự drop/reset để vượt qua guard.

Lần tạo tài liệu này chỉ chạy verifier file tĩnh, không truy cập database/provider. Verifier so sánh DDL và marker/cấu trúc file; không chứng minh SQL đúng cú pháp, trigger chạy đúng, quyền đúng hoặc RLS thực sự cô lập hai tài khoản. Báo cáo offline ghi READY_FOR_DB_APPROVAL; báo cáo remediation ghi BLOCKED vì RLS integration chưa chạy. Iteration 6 chưa được nghiệm thu.

6 Chạy local và xác minh

Chạy các lệnh từ workspace C:/Users/admin/OneDrive/Desktop/selltime_project. Dự án cần Node.js/npm; bộ tests hiện tại đọc trực tiếp TypeScript qua Node. Nên ghi nhận phiên bản runtime trước khi tái lập. Không cần password hay API secret mới để xem persona DEMO.

```
node --version
npm --version
npm ci
npm run dev
```

Trên checkout mới có package-lock đồng bộ, npm ci cài dependency theo lockfile. Nếu workspace đã có dependency và thay đổi của người dùng, kiểm tra lockfile/trạng thái trước khi cài lại. Trang DEMO ở http://localhost:3000; trang /auth có thể mở nhưng thao tác Auth mặc định bị khóa khi thiếu cấu hình.

Cấu hình và credential

Các tên biến Auth: SELLTIME_AUTH_ENABLED, SELLTIME_AUTH_SUPABASE_URL, SELLTIME_AUTH_SUPABASE_ANON_KEY, SELLTIME_AUTH_ORIGIN. Chỉ bật sau khi môi trường test được phê duyệt, migration được review và có kế hoạch kiểm chứng. Production yêu cầu HTTPS; localhost HTTP chỉ dành cho development. Không đặt service-role key vào source hoặc biến public.

AI server đọc GEMINI_API_KEY; source còn hỗ trợ tên legacy NEXT_PUBLIC_GEMINI_API_KEY. Tránh đưa khóa AI vào cấu hình public; cần review nhánh legacy trước khi bật AI LIVE. Tài liệu không đọc .env.local, không chứa giá trị credential và không xác nhận môi trường LIVE đang bật.

Git đang có staged deletion của tệp credential cũ trong src/Password-Supabase; dữ liệu local được giữ nguyên. Xóa khỏi index không xóa credential khỏi lịch sử Git. Nếu credential từng được chia sẻ/commit và còn hiệu lực, cần rotation bởi chủ credential; lần này không đánh giá giá trị, không xoay khóa và không thay trạng thái Git.

Kết quả kiểm tra trong lần tạo tài liệu

Lệnh đã chạy ngày 11/10/2026	Kết quả và giới hạn
node src/__tests__/selltime-core.test.mjs	PASS 45/45; domain regression, không thay thế test UI
node src/__tests__/auth-ownership.test.mjs	PASS 17/17; provider/database mock, 0 request thật
node src/__tests__/build-realpath.test.cjs	PASS 3/3; trường hợp fallback realpath và truyền lỗi
node scripts/verify-rls-preparation.cjs	PASS kiểm tra file tĩnh; SQL NOT_RUN

Core test phát cảnh báo MODULE_TYPELESS_PACKAGE_JSON của Node nhưng exit 0; không sửa package chỉ để ẩn cảnh báo. Không chạy test connection/seed vì các script đó có thể truy cập dữ liệu thật.

Báo cáo verification-6-remediation đã ghi npx tsc --noEmit --incremental false PASS và npm run build PASS. Hai lệnh này không được chạy lại trong task chỉ tạo tài liệu. npm run build hiện preload scripts/windows-realpath.cjs; tests xác minh fallback Windows EPERM, nhưng lần remediation không tái hiện EPERM và không kết luận đã sửa nguyên nhân permission. Kiểm thử browser/cookie HTTPS, email delivery và RLS thật chưa có bằng chứng PASS.

7 Các phần cần cải thiện và lộ trình đề xuất

Hiện trạng phù hợp để trình diễn khái niệm và thu thập phản hồi về trải nghiệm tìm ca. Chưa đủ bằng chứng để mở tuyển dụng, điểm danh và thanh toán thật. Quyết định ra thị trường cần dựa trên validation kỹ thuật cùng thử nghiệm nhu cầu thực tế, không dựa riêng vào số test PASS.

Vấn đề đã ghi nhận	Hướng xử lý cần được review
RLS chưa chạy trên Supabase test	Thực thi kế hoạch đã chuẩn bị trên project được duyệt; lưu log/assertion và hậu kiểm rollback
Request body được buffer trước giới hạn	Đọc stream với giới hạn byte trước khi parse; kiểm thử request không có Content-Length
Validation shift và enum chưa thống nhất	Kiểm tra range giờ, enum domain/SQL, budget và giới hạn số tiền
Signup trùng email DEMO unbound	Thiết kế xử lý collision, không tự ghép danh tính theo email
Refresh outage làm mất cookie	Review thông báo và trải nghiệm đăng nhập lại, giữ nguyên nguyên tắc fail-closed
DEMO persistence/checkout/lock	Consumer tests cho MessagesTab, CheckoutModal, callback payout và state sau reload
AI fallback và API chưa có kiểm soát truy cập	Sửa content/metadata nhất quán; bổ sung auth, quota, rate limit và đo chi phí

Thứ tự triển khai đề xuất

Pha 1 — Nghiệm thu Auth và ownership. ChatGPT review diff/log hiện có; giải quyết finding security đã ghi; xin phê duyệt database test riêng và chạy RLS. Điều kiện hoàn thành gồm hai tài khoản cô lập dữ liệu, chống role/owner/sender spoof, đúng cookie/Origin trên browser test và không mất dữ liệu người dùng. Không tự triển khai pha này từ tài liệu.

Pha 2 — Lifecycle server và giao diện LIVE. Thiết kế application, approval, check-in, checkout và completion với state machine, ownership và chống thao tác lặp. Nối Candidate/Employer vào backend đã nghiệm thu; kiểm tra đồng bộ và reload. Giữ DEMO có nhãn rõ để người dùng phân biệt.

Pha 3 — Nền tảng quản trị và vận hành. Bổ sung Admin Dashboard, API/guard cụ thể, audit log, quản lý tranh chấp và theo dõi lỗi. Role ADMIN hiện có không thay thế các năng lực này. Xác định luồng khóa/mở quyền và quyền truy cập dữ liệu tối thiểu.

Pha 4 — Pilot giới hạn và payment. Đề xuất phỏng vấn ứng viên/cơ sở mục tiêu, thử pilot phạm vi nhỏ với tiêu chí đã thống nhất. Chỉ tích hợp payment sau khi có đối soát, hoàn tiền, xử lý tranh chấp và yêu cầu pháp lý/vận hành được đánh giá. Theo dõi tỷ lệ ứng tuyển được duyệt, hoàn thành ca, no-show, tranh chấp và mức sử dụng lặp lại; chưa có dữ liệu thực đo trong workspace để đặt kết luận thương mại.

Lộ trình là đề xuất để review, không phải ủy quyền triển khai. Cần thống nhất metric/điều kiện nghiệm thu từng pha trước khi mở pha tiếp theo.

8 Nguồn đối chiếu và quy trình bàn giao

Tài liệu ưu tiên code hiện tại và báo cáo có giới hạn kiểm chứng rõ ràng. Những tuyên bố trong PRD hoặc báo cáo cũ về chức năng LIVE cần được đối chiếu lại; không mặc định chuyển thành kết quả nghiệm thu hiện tại.

Nguồn trong workspace	Nội dung đối chiếu
package.json	Dependency range, scripts dev/build/start
src/app/page.tsx, src/application/store.ts	Persona, state, luồng DEMO và localStorage
src/components	Modal Auth/check-in/checkout/payment, chat và Employer Dashboard
src/domain	Types, matching và Trust Battery
src/infrastructure/auth, src/app/api	Xác minh server, Origin, role và ownership
auth-ownership.md	Phạm vi Auth và giới hạn triển khai
execution-summary — remediation	Test/typecheck/build đã ghi; trạng thái BLOCKED
execution-summary — offline	Chuẩn bị RLS, static PASS và DB approval còn thiếu
deferred-work.md	Finding chưa xử lý và bằng chứng review
rls-integration-test-plan.md	Kế hoạch thực thi database có checkpoint quyền

Quy trình Codex và ChatGPT

Codex thực thi một task đã được cho phép, gửi báo cáo EXECUTED và bằng chứng. ChatGPT review độc lập, kết luận DONE hoặc PLAN. Chỉ bắt đầu vòng tiếp theo khi phạm vi được cho phép. Tài liệu này không nghiệm thu Iteration 6 thay ChatGPT và không yêu cầu thay đổi cấu hình ChatGPT.

Khi gửi tài liệu để review, cần yêu cầu phân biệt ba mức bằng chứng: code có trong working tree, test mock/static PASS, và hành vi đã kiểm chứng trên hệ thống thật. Với Auth/RLS, mức cuối vẫn đang thiếu. Các lệnh có thể seed, chạy SQL hoặc truy cập provider phải có scope riêng; không suy ra quyền chạy từ việc chúng xuất hiện trong tài liệu.

Thuật ngữ dùng trong tài liệu

- DEMO: persona và dữ liệu mô phỏng; không phải danh tính được server xác minh.
- LIVE: thao tác với tài khoản/dữ liệu thật, cần cấu hình và kiểm chứng riêng.
- Ownership: kiểm tra người dùng có quyền trên đúng bản ghi hoặc hội thoại.
- RLS: Row Level Security của PostgreSQL; hiệu lực thực tế cần migration và database test.
- Fail-closed: từ chối khi không xác minh được, không tự hạ xuống dữ liệu hoặc quyền mock.
- Escrow: dữ liệu ký quỹ; hiện chưa có payment/đối soát thật trong luồng ứng dụng.

NEXT_EXPECTED_STEP: STOP. Chủ dự án gửi tài liệu và execution output cho ChatGPT review; không tự bắt đầu pha triển khai tiếp theo.